文章编号:1009-4873(2023)04-0029-04

CSRF 攻击技术浅析

杨 朝 升

(石家庄职业技术学院 信息工程系,河北 石家庄　050081)

摘　要:在阐述 CSRF 攻击原理的基础上,结合攻击案例剖析 CSRF 的攻击过程,提出针对性的防护手段,如验证码、referer 和 token,同时建议抓住 CSRF 攻击本质,利用"不可预测性原则"将涉及重要业务过程的参数进行加密或随机数处理,让攻击者无法构造出参数值,从而达到有效防御的目的.

关键词:CSRF;攻击;防护;应用程序

中图分类号:TP393.08　　**文献标志码**:A

跨站请求伪造(CSRF)最早在 2000 年被国外的研究人员提出,国内直到 2006 年才被提及和研究. 2008 年,CSRF 攻击方式开始升级,主要通过蠕虫脚本的方式在大型社交类应用程序中泛滥,产生了很大的影响. 尽管 CSRF 的危害很大,但是很多开发者和安全从业人员对其仍然不够重视,使得很多 Web 系统对 CSRF 防备不足. CSRF 是一种危害大且非常隐蔽的攻击方式,在安全界被称为"沉睡的巨人",连续多年位于 OWASP(全球知名的 Web 安全研究组织)提供的十大 Web 安全问题前列. 本文通过分析 CSRF 的渗透攻击过程,提出避免遭受 CSRF 攻击的防御手段,以期为维护网络安全提供借鉴.

1　CSRF 简介

目前,黑客攻击已成为非常严重的网络安全问题. 伴随着 Internet 的快速发展和普及,在电子商务、政务系统、医疗平台等领域,Web 应用发展迅速. Web 技术虽然给各行各业带来了便利和发展,但针对 Web 系统的攻击也层出不穷. 许多黑客甚至可以突破 SSL 加密、防火墙及入侵检测系统攻入 Web 应用网站的内部,窃取、篡改信息. 而利用 browser 漏洞及黑客攻击方法,很容易获取 Web 应用系统中存储的用户资料,如用户名、密码及其他保密信息. 攻击手段和过程也趋于工具化、流程化.

OWASP 提供的 top 10 Web 安全问题列表见表 1.

表 1　OWASP 提供的 top 10 Web 安全问题列表

排序	安全问题
1	Cross Site Scripting (XSS)
2	Injection Flaws(SQL Injection, Command Injection)
3	Malicious File Execution
4	Insecure Direct Object Reference
5	Cross Site Request Forgery (CSRF)
6	Information Leakage and Improper Error Handling
7	Broken Authentication and Session Management
8	Insecure Cryptographic Storage
9	Insecure Communications
10	Failure to Restrict URL Access

由表 1 可知,在 OWASP 统计的所有安全威胁中,CSRF 攻击是常见的 Web 安全攻击类型之一. Web 程序提供了友好的用户交互界面,正常合法的用户通过 GET 或者 POST 表单,将合法请求数据传送给 Web 程序,但是 Web 程序与用户之间的合法会话却可以被攻击者通过 browser 漏洞和恶意 script 劫持,甚至伪造受害者的请求数据.

CSRF 即是伪造受害者端请求的一种攻击方式,按照 OWASP 的定义,CSRF 攻击时会迫使某个登录的浏览器向易受攻击的 Web 应用发送一个请求,然后以受害者的名义,让入侵者获得利益. 这虽然像跨站脚本攻击(XSS),但它与 XSS 不同. XSS

收稿日期:2022-12-02

作者简介:杨朝升(1986-),男,石家庄职业技术学院讲师,研究方向:网络安全.

通常攻击客户端即 browser，而 CSRF 则主要攻击 server，CSRF 伪造的业务流程会利用合法用户的身份达成攻击. XSS 攻击原理更简单，流行面更广；而 CSRF 比较“小众”，但它造成的危害却并不比 XSS 小，攻击者只要利用如电子邮件或聊天软件发送的链接等就能诱导用户在毫不知情的情况下执行隐藏的非本意操作，例如，如果用户登录网银查看账户余额，在没有退出当前网银系统的情况下去访问某贴吧网站，而攻击者恰好在该贴吧中精心构造了一个恶意链接，通过感兴趣的话题等手段诱使该用户点击该恶意链接，就会让该用户账户中的钱在不知情的情况下被转走. CSRF 能够攻击成功的原因在于，重要操作的所有参数都可以被攻击者猜测到[1]. 合法请求和 CSRF 恶意攻击行为的区别见图 1.

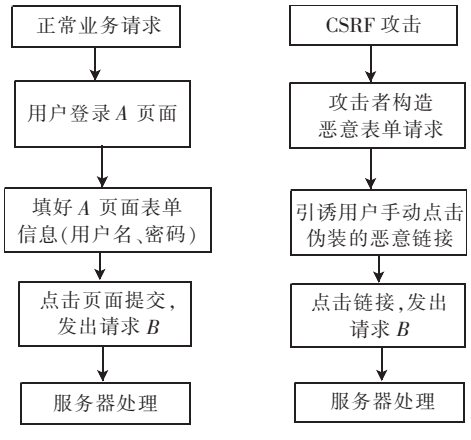

图 1 正常请求与 CSRF 恶意请求的区别

2 CSRF 攻击原理

HTTP 协议是无状态协议，大部分网站通过 cookie 识别用户身份，进行 session 追踪. 虽然 cookie 机制解决了 HTTP 协议的无秩序状态，允许一个用户在访问一个 Web 系统的多个页面时只进行一次身份认证，提升了用户的浏览网体验，但之后访问网站就会自动带上这个身份标识 cookie. 如果这期间浏览器被恶意控制并在用户不知情时请求了网站的 URL，可能就会执行一些违背用户意愿的操作，如修改个人资料、添加管理员后台密码等. 而这并不是用户真正想发出的请求，是伪造请求，这些请求可以从第三方网站提交，即跨站[2]. CSRF 并没有使攻击者获取到受害者的 cookie 值，只是利用受害者本人去点击相关链接，由受害者本人完成 CSRF 攻击. 临时 cookie 在关闭浏览器后失效，而本地 cookie 会在到达响应头中 expires 属性指定的时间后自动失效[3]. 主流浏览器如火狐、chrome 等在进行跨域资源请求时默认允许携带第三方 cookie，这就为 CSRF 攻击创造了条件. CSRF 攻击原理见图 2.

用户 C 利用用户名、密码成功地登录社交网站 A，网站 A 会给 C 颁发一个独一无二的标识 C 身份的 cookie. C 和 A 之间的请求、响应、交互均通过该 cookie 值来完成身份认证.

攻击者 B 想加 A 为好友，但 A 不同意. 这时，B 想通过攻击手段来实现加好友，于是他研究了一个加好友的 HTTP 请求操作，即通过本地抓包研究请求，构造出一个链接，当点击这个链接时，就相当于向服务器提交了一次请求，内容是请求的账户将添加 B 为好友. 当 B 自己提交这个链接请求时，由于请求中带的 cookie 与服务器颁发给 C 用户的 cookie 不一致不能实现加好友，这时 B 将构造的链接通过各种方法诱惑 C 去点击它(包括发送链接给 C 点击；在 B 网站构造 XSS，使得 C 在访问 B 时，自动触发并发送相关链接)，如果 C 没有退出 A 网站(这个前提很重要，因为 C 如果关闭了网站浏览器，则意味着 cookie 需要重新颁发)，却点击了这个构造的链接，这个请求就包含着 C 的合法 cookie，对于服务器 A 来说，它会认为 C 发起了一次“添加 B 为好友”的合法请求，因此会接受这次操作，从而 B 就达到了加好友的目的.

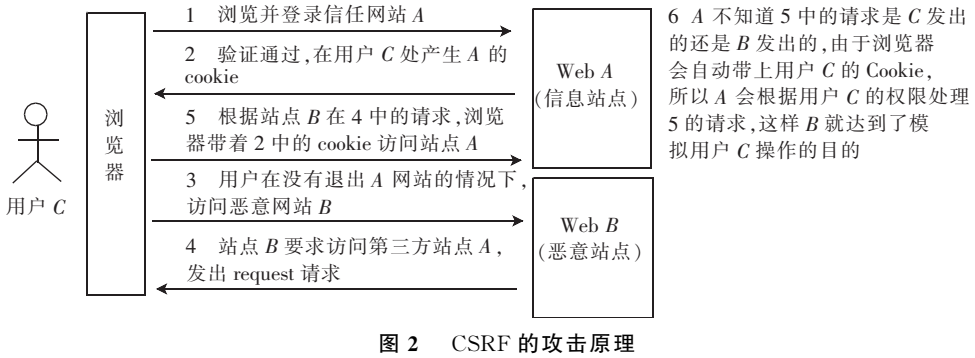

图 2 CSRF 的攻击原理

3　CSRF 渗透案例与分析

3.1　CSRF 渗透案例说明

本案例中,受害者在某个贴吧自己 ID 下的所有的虚拟货币全部丢失.受害者于一周前在某台机器上登录了一次自己的账号,当时虚拟货币还在,一周后再次登录时发现自己 ID 下所有的虚拟货币全部丢失.受害者用自己的账号登录贴吧网站后,在未退出当前系统的情况下,又访问了某论坛中的图片消息,当他点击图片消息时,图片并没有显示完全,见图 3,受害者并没有在意这张没有加载成功的图片,关闭图片显示后就离开了.

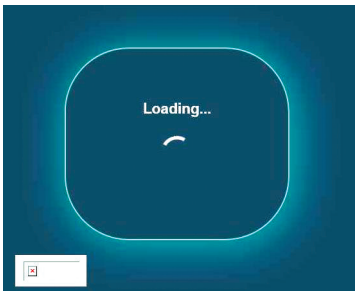

图 3　恶意图片截图

一周后,当受害者再次以自己的账号登录某贴吧网站后,发现虚拟货币全部丢失,受害者认为是自己的机器中了病毒,将杀毒软件升级杀毒后,用不同的浏览器登录该贴吧查看账户的虚拟货币,结果显示的仍是无虚拟货币.

3.2　CSRF 案例分析

分析这个案例可知,当受害者点击自己感兴趣的 ID 链接时,有张图片没显示,于是受害者再次打开那个论坛,并找到当时的贴子,查看了这张图片,发现是 ☒,查看该图片的属性,发现其地址是:http://www.explorer.org/tto/xss_post_forwarder.php? woke=http://passport.***.com/ sex=1&email = attack @ xx. com&sdv = &zodiac = 0&birth_year=0(省略部分代码).

仔细分析这个地址,发现这是一个精心构造的带有正常网银系统转账业务流程的请求.此请求是恶意的,因为它通过伪造请求数据包并劫持合法用户身份,偷偷地将受害者 ID 下的所有资产转移给发贴人.

由于大多数网站具备 cookie 使用时间验证策略.当用户登录网站上自己的账户时,在一段时间内本地计算机不需要再次验证就可以对这个用户进行操作,而当链接出现在 SRC(图片的链接)上时,浏览器就会按照本地的 cookie 去加载这个 URL,而网站的 cookie 是未过期的,所以网站 A 验证了来源请求的 cookie 是合法的.而服务器验证用户的身份是通过 cookie 识别来完成的,所以攻击者盗用了用户的 cookie 即盗用了用户的身份,以合法用户的身份发起了恶意请求,CSRF 攻击就发生了.

3.3　CSRF 攻击可能造成的伤害

如果攻击取得成功,CSRF 攻击可能造成如下伤害:修改受攻击者在网站的设置(比如员工在公司网站中的 ID 内容);修改公司的硬件防火墙设置;使用受攻击者的登录信息在网站中发表评论或留言;通过受攻击者的 IP 地址发表匿名留言;将资金转移到另一个用户账号中;窃取有价值的资料;运行恶意软件,留下很少或不留下能查明真实攻击者的痕迹;进行股票交易;订阅在线服务等[4].

4　CSRF 防御策略

(1)通过验证码防御 CSRF

目前,对于 CSRF 攻击的防御最基础的方法是强制验证码机制,这也是最简洁有效的.CSRF 攻击的原因在于用户在不知情的情况下被动地进行网络请求,利用验证码强制用户与服务器建立有效的交互机制,就能够很好地遏制 CSRF 攻击,但是在很多场景下需要考虑用户体验的效果,验证码不能随时应用,故验证码机制只能作为辅助手段.

(2)通过 referer 防御 CSRF

常见的 Web 业务间往往是有关联的,比如银行转账业务必须在登录成功后才能进行,因此可以通过验证 referer 即验证当前网页是从哪个页面链接的来防御 CSRF 攻击,但不是所有的服务器都能保证取得 referer,很多服务器出于安全考虑往往限制 referer 的使用.

(3)通过 token 防御 CSRF

CSRF 攻击之所以能够成功,是因为攻击者可以完全伪造用户的请求,该请求中用户验证信息均存在于 cookie 中,因此攻击者可以在不知道这些验证信息的情况下直接利用用户的 cookie 来通过安全验证[5].一般的合法请求需要登录 A 页面进行表单内容信息的填写,在客户请求 A 页面等待服务器的响应,服务器返回 A 页面的内容时,可以在返回的表单中插入一个用户不可见的 token 隐藏字段,这个字段对应的值是根据一定的算法生成的.用户在填写好表单后提交页面请求 B,请求 B 中就会携带该 token 值.而当请求再次发生时,就会对请求中的数据进行检查,查看是否有该 token 值并且是否和之前发送给用户的 token 值一致,正常的合法请求是一致的,但

是CSRF攻击则不然，由于其没有登录 *A* 页面，因此直接对 *B* 页面的请求中肯定没有token，这样Web系统就可以判断为CSRF攻击.

如果恶意攻击者通过客户端抓包获取到了token，或者通过其他方式从受害者处获取到了token，也不能绕过服务器的检测. 首先这个token是根据一定的算法生成的，影响它的因素有源IP、时间等，所以即使获取了受害者的token并加入到请求参数中，由于源IP、时间等不一致，Web系统同样能够识别是否为CSRF攻击. 但这种保存token的方法是建立在cookie不会被攻击者截获的前提下的. 如果Web系统同时存在XSS漏洞，那么攻击者可以通过XSS来获取cookie，CSRF防护也会失效.

Token实现的CSRF防护原理图见图4.

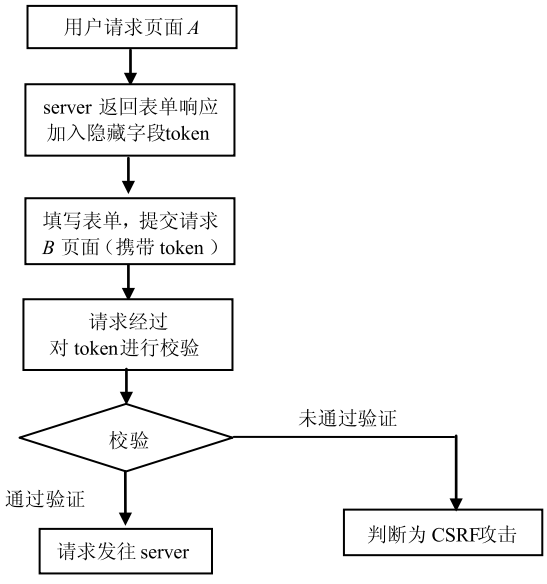

图4 Token防护原理图

5 CSRF防御开发建议

(1)对Web应用中的身份标识信息cookie，要尽可能地缩短验证时间，减少cookie暴露的风险.

(2)CSRF之所以能够成功，究其原因是重要业务过程中的参数可以被攻击者猜测到，所以建议开发人员重点梳理重要业务中的参数，并对其进行加密或者随机化处理，从而让攻击者无法猜测到真实的参数值. 简而言之，通过“不可预测性原则”保护Web系统.

(3)相对于GET提交表单方式，虽然POST也存在安全威胁，但POST提交方式更隐蔽，更安全，建议提交表单业务采用POST方式.

(4)在使用过程中，要注意token的保密性，防止token被XSS漏洞泄露，尽量把token写入表单中而不是放在URL中，避免通过referer的方式被窃取.

参考文献：

[1] 吴翰清. 白帽子讲WEB安全[M]. 北京：电子工业出版社，2012：120-121.

[2] 季凡，方勇，蒲伟，等. CSRF新型利用及防范技术研究[J]. 信息安全与通信保密，2013(3)：75-76.

[3] 陈万坡. 基于WEB应用程序技术的CSRF攻击与防御技术[D]. 上海：上海交通大学，2015.

[4] DAFYDDSTUTTARD，MAREUS PINTO. 黑客攻防技术宝典：Web实战篇[M]. 北京：人民邮电出版社，2009：22-24.

[5] 张悦，杨学全. 基于服务器端CSRF防御模块的设计与实现[J]. 信息技术与信息化，2014(7)：45-46.

责任编辑：金 欣

An analysis of CSRF attack technology

YANG Zhao-sheng

(Department of Information Engineering, Shijiazhuang University of Applied Technology, Shijiazhuang, Hebei 050081, China)

Abstract: On the basis of the attack principle of CSRF, this paper analyzes CSRF with illustrative cases, and puts forward protection measures, i. e., verification code, referer and token. At the same time, it is recommended to grasp the essence of CSRF attack, and use the unpredictability principle to encrypt or apply random number parameters involving business processes, so that attackers could not construct parameter values.

Key words: CSRF; attack; protection; application program